

TEMA 3.2

MANEJO Y CONTROL DE LAS VULNERABILIDADES

6CV3 - Equipo 4

- Flores Madrigal Diego
- Muñoz Sánchez Fernando
- Contla Mota Luis Andrés



REGULACION Y GESTION

ISO/IEC 27001 es una norma internacional que establece los requisitos para implementar un Sistema de Gestión de Seguridad de la Información (SGSI).

Su objetivo es proteger la confidencialidad, integridad y disponibilidad de la información mediante gestión de riesgos.

Un SGSI es un conjunto estructurado de:

- Políticas
- Procesos
- Procedimientos
- Recursos
- Controles

La organización debe obtener información sobre vulnerabilidades técnicas de los sistemas de información utilizados, evaluar su exposición y tomar medidas apropiadas para tratar el riesgo asociado.

Esto implica:

- Monitorear fuentes de vulnerabilidades (CVE, fabricantes, boletines).
- Evaluar si la vulnerabilidad afecta a la organización.
- Analizar el nivel de riesgo.
- Aplicar parches o mitigaciones.
- Documentar todo el proceso.

ACTIVOS Y CMDB

Una vulnerabilidad solo puede gestionarse si sabes que el activo existe.

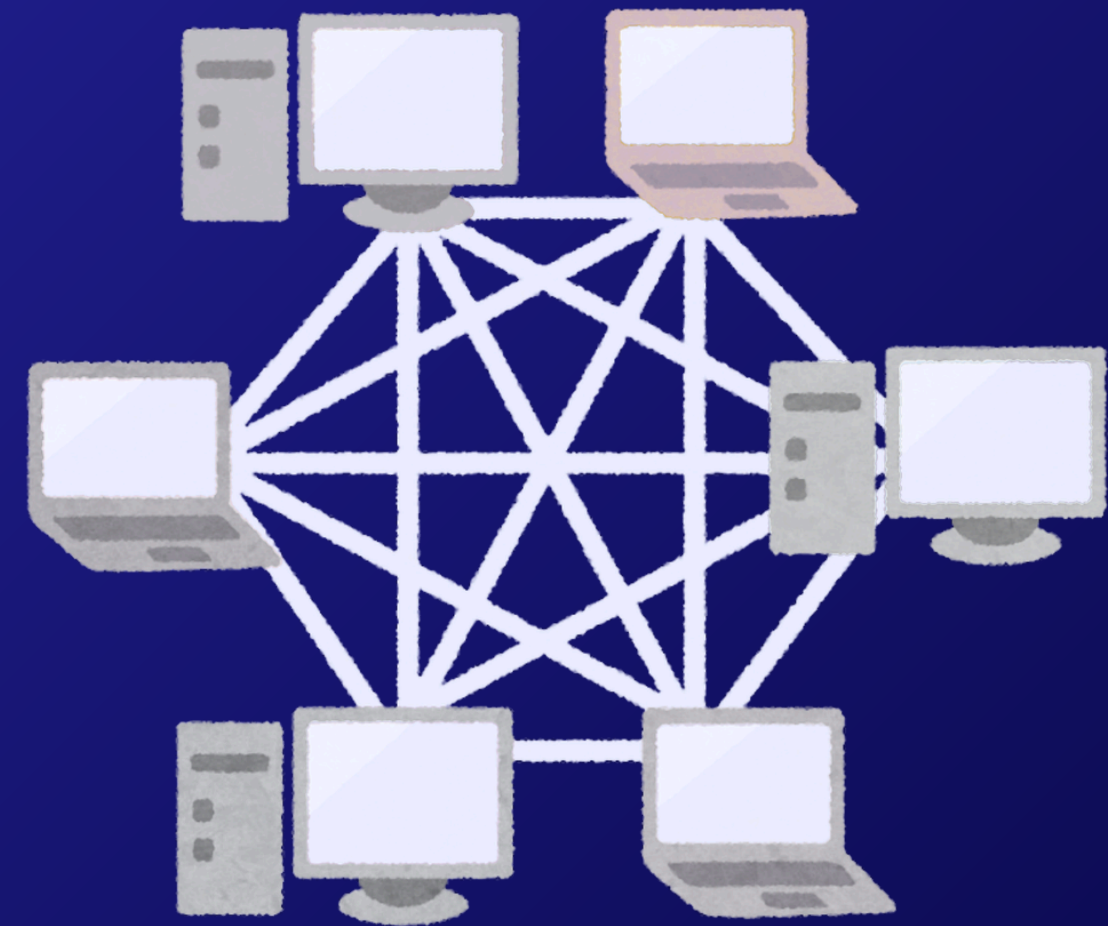
CMDB (Configuration Management Database)

Es la base de datos donde se registran:

- Servidores
- Equipos de red
- Aplicaciones
- Versiones de software
- Relaciones entre sistemas

Sin CMDB:

- No sabes qué parchar.
- No sabes qué impacto tiene una vulnerabilidad.
- No puedes priorizar correctamente.



CICLO DE VIDA OPERATIVO

Detección

Consiste en identificar que vulnerabilidades existentes en los sistemas.

- Escaneo por red

- Se realiza desde un equipo externo.
- Detecta servicios expuestos y versiones visibles.
- No requiere instalación local.

- Escaneo con agente

- Se instala software en el equipo.
- Accede al sistema operativo internamente.
- Mayor precisión.

- Escaneo con credenciales

El escáner usa credenciales administrativas para acceder al sistema.

Ventajas:

- Detecta vulnerabilidades ocultas.
- Identifica configuraciones inseguras.

Riesgos:

- Las credenciales deben protegerse.

CICLO DE VIDA OPERATIVO

CVE

Common Vulnerabilities and Exposures (CVE) es un sistema internacional que asigna identificadores únicos a vulnerabilidades conocidas.

Formato:

CVE-AÑO-FOLIO

Sirve para:

- Estandarizar nombres.
- Facilitar comunicación técnica.
- Integrar herramientas de escaneo.

Analisis y Clasificacion

Después de detectar vulnerabilidades se debe:

- Confirmar que aplica al activo.
- Evaluar severidad.
- Analizar impacto .

Priorización Basada en Riesgo

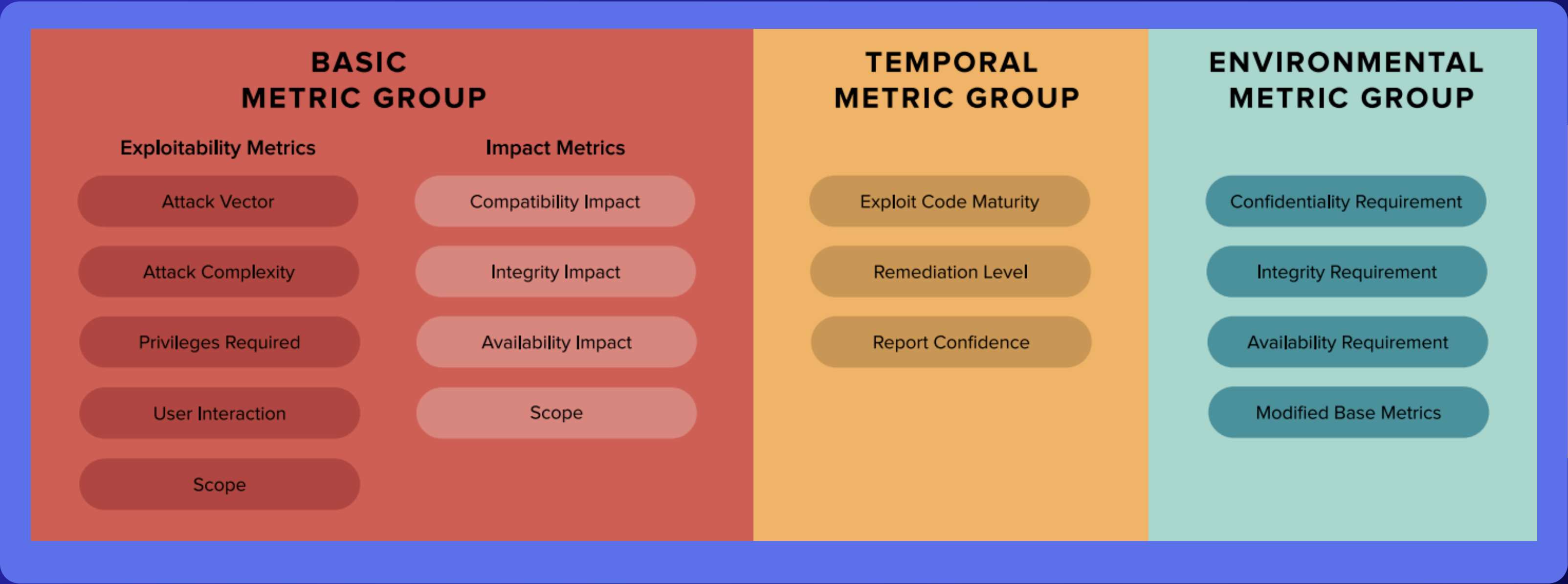
No se prioriza solo por severidad técnica, sino por:

- Exposición
- Criticidad del activo
- Impacto en operación

METRICAS DE SEVERIDAD Y PROBABILIDAD

COMMON VULNERABILITY SCORING SYSTEM - CVSS 3.1/4.0

Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0





EPSS es un modelo probabilístico que utiliza telemetría global para estimar la probabilidad de explotación activa.

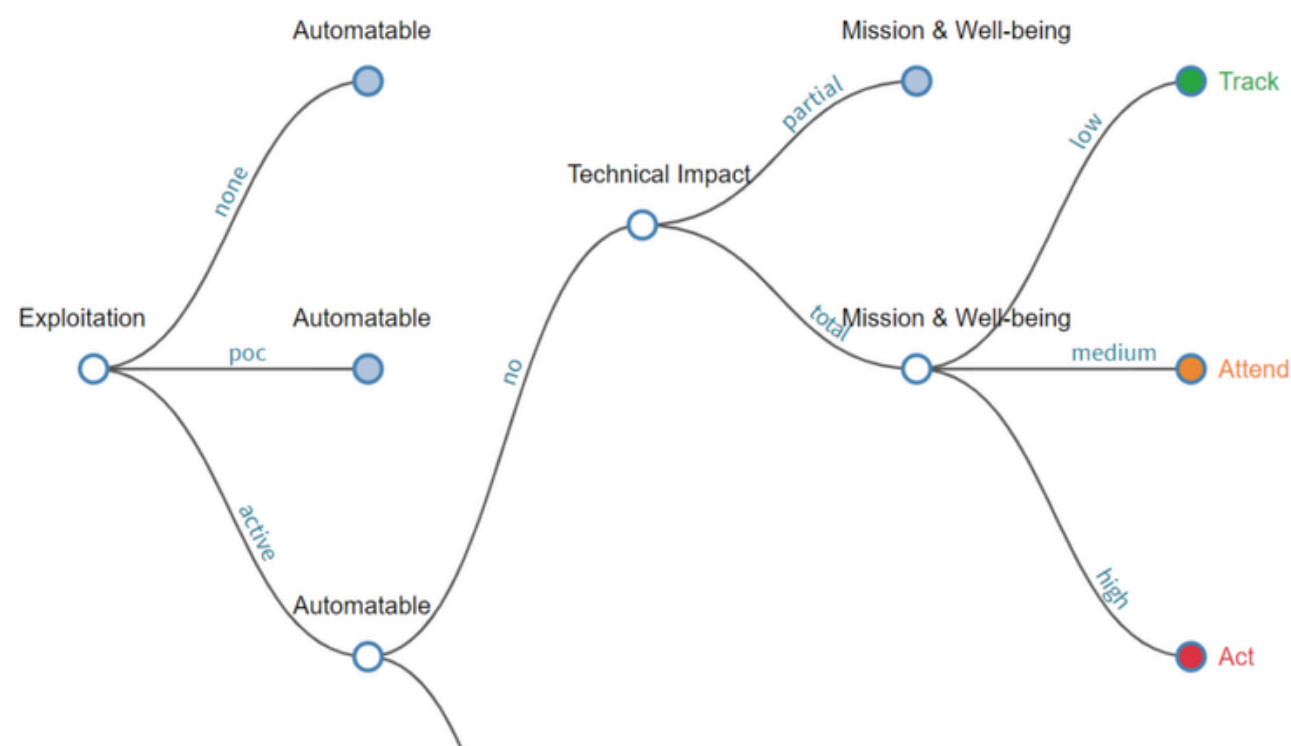
A diferencia de CVSS, que es estático, EPSS es un puntaje diario. Utiliza variables como:

- Presencia de la vulnerabilidad en kits de explotación (Exploit Kits).
- Menciones en repositorios de código (PoCs en GitHub).
- Volumen de escaneo detectado en honeypots de organizaciones como Shadowserver o GreyNoise.

Un percentil EPSS alto indica que la vulnerabilidad está siendo activamente buscada por actores de amenaza, lo que eleva la urgencia de remediación independientemente de si el CVSS es moderado.

**EXPLOIT PREDICTION SCORING
SYSTEM - EPSS**

STAKEHOLDER-SPECIFIC VULNERABILITY CATEGORIZATION (SSVC)



Este es un sistema de decisión basado en árboles lógicos (Decision Trees) que evita los sesgos de los puntajes numéricos.

Evalúa:

- State of Exploitation: (None, PoC, Active).
- Exposure: (Small, Controlled, Open).
- Mission Impact: El efecto en la misión principal de la organización.
- Decision Outcomes: El resultado no es un número, sino una acción: Defer (Postergar), Scheduled (Programar), Out-of-Cycle (Urgente) o Immediate (Inmediata).



La respuesta técnica ante una vulnerabilidad identificada se rige por el ciclo de vida de NIST SP 800-40 y se clasifica según la naturaleza de la intervención.

REMEDIACIÓN Y MITIGACIÓN



REMEDIACIÓN



MITIGACIÓN



**ACEPTAR EL
RIESGO**

EL “GAP” ENTRE SEGURIDAD Y OPERACIONES

¿POR QUÉ EXISTE EL GAP?

OBJETIVOS EN CONFLICTO

- Seguridad: reducir riesgo. Parchar rápido, endurecer controles.
- Operaciones: maximizar disponibilidad. Evitar cambios que “rompan” producción.

CONCEPTOS CLAVE

- SLI (Indicador de nivel de servicio): métrica
- SLO (Objetivo de nivel de servicio): meta interna
- SLA (Acuerdo de nivel de servicio): compromiso contractual.

EJEMPLO

Parchar una vulnerabilidad crítica vs mantener 99.9%: el “costo” del downtime compite con el “costo” del riesgo.

¿CÓMO CERRAR EL GAP: ACUERDOS, MÉTRICAS Y PRÁCTICA?

ACUERDOS CLAROS BASADOS EN RIESGO

- Definir Patch SLA por severidad (Crítica / Alta / Media).
- Permitir excepciones con: riesgo aceptado + compensaciones (WAF, segmentación, hardening).

MODELO SRE: "ERROR BUDGET"

- Si se "gasta" el presupuesto de error (muchas caídas), se congela cambio no esencial.
- Si hay margen, se prioriza seguridad/tech debt (parches, hardening).

PATCH MANAGEMENT SIN "ROMPER PRODUCCIÓN"

- QA/Staging con pruebas automatizadas (smoke/regression).
- Despliegues por fases (rings): piloto
- Canary / Blue-Green / Rolling + rollback rápido.

MÉTRICAS COMPARTIDAS

MTTR de vulnerabilidades, % de parches en tiempo, incidentes por cambio, disponibilidad vs riesgo residual.

AUTOMATIZACIÓN Y HERRAMIENTAS (CIS CONTROL 7)

CENTER FOR INTERNET SECURITY

OBJETIVO

Detectar y reducir vulnerabilidades de forma continua

CICLO

- Descubrir
- Escanear
- Priorizar
- Remediar
- Verificar

PRIORIDAD REAL

CVSS (puntaje de severidad de vulnerabilidades) +
Exposición + Criticidad +
Exploit activo

ATERRIZAJE CON SOFTWARE REAL: ESCANEEO + PARCHES + MONITOREO

ESCANEEO

Escáneres de vulnerabilidades

- Tenable/Nessus
- Qualys
- Rapid7

PARCHES

- Despliegue por anillos: piloto → grupos → producción completa.
- Políticas: reinicios, ventanas de mantenimiento, rollback, reportes de cumplimiento.

CONTINUO

- Cambios diarios
- Nuevas CVEs
- Monitoreo/alertas en tiempo real

FLUJO RECOMENDADO

- Escáner detecta
- Se crea ticket (ServiceNow/Jira)
- Se asigna
- Se parchea (Intune/SCCM)
- Se valida con re-escaneo
- Dashboard ejecutivo (KPIs).

REFERENCIAS

Microsoft. (s.f.). ¿Qué es la gestión de vulnerabilidades? <https://www.microsoft.com/es-mx/security/business/security-101/what-is-vulnerability-management>

FIRST. (s.f.). [Exploit Prediction Scoring System \(EPSS\)](https://www.first.org/epss/). <https://www.first.org/epss/>

FIRST. (s.f.). [Common Vulnerability Scoring System \(CVSS\)](https://www.first.org/cvss/). <https://www.first.org/cvss/>

SSVC Framework. (s.f.). [Stakeholder-Specific Vulnerability Categorization \(SSVC\)](https://sscv-framework.org). <https://sscv-framework.org>

IBM. (s.f.). ¿Qué es la gestión de vulnerabilidades? <https://www.ibm.com/mx-es/think/topics/vulnerability-management>